

IPSEC REGULATORY AUDIT & CRYPTOGRAPHIC HEALTH

# IPsec VPN Security Assessment & Framework Audit

Comprehensive evaluation against NIST SP 800-77 Rev. 1, RFC 8221, and NSA CNSA 2.0 cryptographic mandates

100

GRADE A - COMPLIANT

CONDITIONAL COMPLIANCE · ATTENTION REQUIRED

The IPsec deployment scored 100.0 out of 100 (GRADE A - COMPLIANT), indicating robust transport confidentiality via AES-256-GCM encryption. However, critical gaps in Child SA forward secrecy and static shared key authentication require remediation under NIST SP 800-77 Rev 1.

## Section 1: Scope & Regulatory Framework

Definition of audit benchmarks (NIST SP 800-77 Rev. 1, RFC 8221, NSA CNSA 2.0)

AUDIT SCOPE & TARGET GATEWAYS

PCAP Forensics: sih26\_asim\_golden.pcap (100.119.32.83 ...)

ASSESSMENT TIMEFRAME

Full Capture Duration: 142.08s (557 packets)

| REGULATORY BENCHMARK  | TITLE & JURISDICTION           | MANDATED CRYPTOGRAPHIC REQUIREMENTS                                  | AUDIT COMPLIANCE VERDICT |
|-----------------------|--------------------------------|----------------------------------------------------------------------|--------------------------|
| NIST SP 800-77 Rev. 1 | Guide to IPsec VPNs            | Mandates AEAD authenticated ciphers (AES-GCM), enforces Perfect ...  | COMPLIANT                |
| RFC 8221              | ESP and AH Cryptographic Re... | Classifies AES-GCM as MUST implement; strictly deprecates 3DES (...) | COMPLIANT                |

## Section 2: Cryptographic Health Audit

Granular evaluation of symmetric ciphers (AES-GCM vs. CBC/3DES) and hashing integrity (SHA-256 vs. SHA-1/MD5)

SYMMETRIC ENCRYPTION CIPHER

APPROVED

AES-256-GCM

Operating Mode: AEAD (Galois/Counter Mode)  
Integrity Tag: 128-bit ICV Authentication Tag  
Key Length: 256 bits

AEAD ciphers combine confidentiality and message integrity in a single pass, eliminating padding oracle vectors (POODLE...

HASHING & MESSAGE INTEGRITY

APPROVED

SHA-256

Digest Size: 256 bits (SHA-256)  
Collision Resistance: Verified (FIPS 180-4 Compliant)  
Deprecated Primitives: MD5 / SHA-1 Not Detected

Collision-resistant cryptographic hashing verified. No legacy SHA-1 or MD5 digests detected.

KEY MANAGEMENT, PROTOCOL & STATE INTEGRITY

# Key Exchange & Protocol Integrity

Diffie-Hellman modulus size verification, post-quantum posture, sequence rollover safeguards, and anti-replay integrity

## Section 3: Key Management & Exchange Audit

Verification of Diffie-Hellman modulus size, post-quantum posture, and PFS rekey enforcement

|                                                                                                                                                                                                                                                  |                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                |                                                                                                                                                                                                                                                                         |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div><div>DIFFIE-HELLMAN MODULUS STRENGTH</div><div>APPROVED</div></div> <div><div>ECP-256</div><div>256-bit Elliptic Curve (~3072-bit ...)</div><div>Meets NIST SP 800-57 Part 1 Rev 5 discrete logarithm strength recommendations.</div></div> | <div><div>PERFECT FORWARD SECRECY (PFS) REKEY</div><div>CRITICAL NON-COMPLIANCE</div></div> <div><div>Active (ECP-256)</div><div>IKE SA: Active (DH Group 19)   0 p...</div><div>Absence of ephemeral DH exchange during Child SA rekey means compromise of long-term credentials enables retrospec...</div></div> | <div><div>POST-QUANTUM CRYPTOGRAPHIC POSTURE</div><div>TRANSITION REQUIRED</div></div> <div><div>CLASSICAL ECC (Pre-Quantum)</div><div>Target: Hybrid ML-KEM-768 (Kyber)</div><div>Migrate to Hybrid ML-KEM-768 (Kyber) + ECP-256 per NSA CNSA 2.0 transition mandate (2026-2030).</div></div> | <div><div>SA ROTATION LIFETIMES &amp; LIMITS</div><div>ALIGNED</div></div> <div><div>3600 seconds (1 Hour)</div><div>1,000 MB (1 GB Transfer Threshold)</div><div>Strict rekey intervals constrain cryptanalytic exposure window under high packet volumes.</div></div> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Section 4: Protocol & State Integrity

Anti-replay window sizing, sequence rollover safeguards, and IKE mode security (e.g., IKEv1 Aggressive Mode detection)

|                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                       |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div><div>ANTI-REPLAY WINDOW SIZING</div><div>ACTIVE &amp; VERIFIED</div></div> <div><div>64-bit sliding window (RFC 4303)</div><div>Kernel IPsec state maintains strict packet sequence bitmap. Zero replay packet injection attempts observed.</div></div> | <div><div>SEQUENCE ROLLOVER SAFEGUARDS</div><div>HARDENED</div></div> <div><div>64-bit Extended Sequence Numbers (...)</div><div>Protects against 2^32 sequence cycling attacks under 10Gbps+ multi-core line-rate traffic. Safe for &gt;500 years.</div></div> | <div><div>IKE MODE SECURITY &amp; DOWNGRADE</div><div>PROTECTED</div></div> <div><div>IKEv2 (RFC 7296)</div><div>IKEv1 Aggressive Mode NOT detected. Unencrypted identity hashing is prevented, neutralizing offline dictionary cracking.</div></div> |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

SIDE-CHANNEL AUDIT & COMPREHENSIVE VULNERABILITY REGISTER

## Side-Channel Audit & Threat Matrix

Traffic Flow Confidentiality (TFC) leakage, itemized CVSS vulnerability register, and post-remediation posture

### Section 5: Side-Channel & Metadata Vulnerability Audit Leakage score based on packet shape predictability, burstiness, and missing Traffic Flow Confidentiality (TFC) padding

SIDE-CHANNEL LEAKAGE SCORE

74

MODERATE RISK

PACKET SHAPE PREDICTABILITY

HIGH PREDICTABILITY

Histogram analysis shows distinct clustering around 1420B (video stream) and 180B (audio codec). Clear a...

BURSTINESS & IAT TIMING

MODERATE LEAKAGE

Inter-arrival timing demonstrates regular 20ms frame intervals, leaking interactive VoIP/stream cadences.

TFC PADDING AUDIT

MISSING / DISABLED (-3 pt...

Activate Traffic Flow Confidentiality (TFC) padding per RFC 4303 §2.7 to mask packet size signatures.

### Section 6: Comprehensive Threat & Vulnerability Matrix Detailed register of discovered vulnerabilities, CVSS base/environmental scores, and audit remediation mandates

| VULN ID          | VULNERABILITY & THREAT VECTOR        | CVSS v3.1 BASE / ENV | SEVERITY | REMEDIATION MANDATE            |
|------------------|--------------------------------------|----------------------|----------|--------------------------------|
| AV-VULN-2026-001 | Absence of Child SA Perfect Forwa... | Base: 7.5   Env: 6.8 | HIGH     | NIST SP 800-77 Rev. 1 §4.2.3   |
| AV-VULN-2026-002 | Static Pre-Shared Key (PSK) Mutua... | Base: 6.5   Env: 5.9 | MEDIUM   | RFC 8221 / Enterprise PKI S... |
| AV-VULN-2026-003 | Missing Traffic Flow Confidential... | Base: 4.3   Env: 3.8 | MEDIUM   | RFC 4303 §2.7 Side-Channel ... |
| AV-VULN-2026-004 | Anti-Replay Window Verification      | Base: 0   Env: 0     | LOW      | RFC 4303 §3.4.3 Anti-Replay    |

0

CRITICAL

1

HIGH

2

MEDIUM

1

LOW

PROJECTED POST-REMEDIATION POSTURE

CURRENT SCORE100 /

100

PROJECTED GAIN+19 pts

PROJECTED SCORE100 /

100

PROJECTED GRADEGRADE

A+ • FULLY

HARDENED

Executing the top two priority directives (enforcing PFS Diffie-Hellman Group 19 on Child SAs and migrating from PSK to X.509 enterprise PKI certificates) immediately eliminates 16 penalty points, elevating the IPsec deployment to complete NIST SP 800-77 Rev. 1 compliance.